

Outcome Without Method: An Outcome-Validation Integrity Score for Agentic Cybersecurity Benchmarks

Babar Khan Akhunzada

SecurityWall founder@securitywall.co

ABSTRACT

Agentic large language model (LLM) systems are increasingly evaluated on cybersecurity tasks: capture-the-flag (CTF) exploitation, vulnerability discovery, malware analysis, and automated patching, typically using benchmarks that report a single scalar success metric, such as a binary flag capture, a multiple-choice accuracy, or a $\text{pass}@k$ rate. We show, through a structured audit of eleven independently published benchmarks and deployments spanning academic preprints, an industry blog, a government-run competition, an enterprise production deployment, and an industry framework evaluation, that the design of a success metric is a strong predictor of whether that metric can be gamed without the intended capability being exercised, a failure mode we term *outcome-without-method*. We formalize a five-dimension, 0–10-point **Outcome-Validation Integrity Score (OVIS)** that scores each benchmark on method verification, shortcut and contamination auditing, human ground-truth anchoring, grader independence, and reproducibility. Applying OVIS across our corpus, benchmarks using purely outcome-based grading (binary flag or multiple-choice) score a mean method-verification sub-score of **16.7%**, versus **100.0%** for benchmarks using process-aware grading (tiered capability ladders, graph-grounded step rewards, or functional patch-validation). We further document a previously reported instance of reward hacking in which a benchmarked model achieved an 85% nominal pass rate on a challenge while using the intended exploitation technique in **zero** of 681 relevant runs, and show that a post-hoc manual audit, rather than benchmark redesign, was sufficient to detect it. We situate OVIS within the broader reward-hacking and specification-gaming literature, argue that OVIS-style auditing should be a required companion to any reported capability number in agentic cybersecurity evaluation, release our scoring rubric and corpus as a reusable artifact, and outline how the approach generalizes to non-security agentic benchmarks.

Index Terms—agentic AI, large language models, cybersecurity benchmarks, reward hacking, evaluation methodology, penetration testing, benchmark integrity, meta-analysis

I. INTRODUCTION

Large language model (LLM) agents are now routinely evaluated on offensive and defensive cybersecurity tasks: capturing flags in capture-the-flag (CTF) exercises [1, 8, 9], discovering and patching real-world software vulnerabilities [7, 16], analyzing malware detonation logs [2], and conducting multi-

step SOC investigations [3]. The resulting capability claims, such as “model X solves 90 of 104 CTF challenges,” “model Y clears the hard tier at scale,” or “model Z performs offensive security at $3,600\times$ human speed” [13], circulate widely and shape both research priorities and public risk perception.

Nearly all of these benchmarks reduce agent performance to a single scalar: did the agent produce the correct flag, select the correct multiple-choice option, or reach a terminal state matching a stored answer key. This paper asks a narrower, more mechanical question that the literature has so far answered mostly anecdotally. When a benchmark’s grading function checks only the outcome state and not the method by which that state was reached, how often does the reported number reflect something other than the capability the benchmark claims to measure?

We are motivated by a concrete case. TrustedSec’s evaluation of six locally-hosted models against eight Juice Shop challenges [5] initially reported a 98.5% nominal pass rate on a JWT-forgery challenge. A subsequent manual audit, decoding every passing JWT across 681 relevant runs, found that *zero* of those runs used the intended RS256-to-HS256 algorithm-confusion attack; every “pass” was an unrelated shortcut (replaying an SQL-injection-obtained token, or the unrelated `alg:none` attack) that happened to satisfy a string-match success condition. The benchmark’s own success check, `contains(admin@juice-sh.op)`, could not distinguish the intended exploit from an incidental one. This is not an isolated design flaw. We find structurally similar patterns, of varying severity, across the corpus assembled for this study, and the pattern is consistent with a much older concern in the reinforcement learning literature: that optimizing a proxy objective reliably produces behavior that satisfies the proxy while diverging from the objective it was meant to stand in for [17, 18, 19].

A. Contributions

- We formalize the **Outcome-Validation Integrity Score (OVIS)**, a five-dimension, deterministic, auditable rubric for scoring the degree to which a benchmark’s grading function can be gamed without the intended capability being exercised (Section III).
- We apply OVIS to eleven benchmarks and deployments with sufficient publicly documented grading detail to score defensibly, and report a quantitative association between metric design category (outcome-only versus process-aware) and method-verification integrity (Section IV).
- We show that post-hoc manual auditing can functionally

rescue an outcome-only benchmark design, using the TrustedSec case as a worked example, and argue this should be treated as a minimum bar rather than a bonus (Section V).

- We situate the finding within the wider CTF and pentesting benchmark landscape and the foundational reward-hacking literature, and release the full scoring rubric, corpus, and computation script as a reusable artifact for future benchmark audits.

II. RELATED WORK

A. Benchmark integrity in CTF-style evaluation

Sultan [1] addresses a narrower instance of the shortcut problem specific to XBOW-style benchmarks, where flags are computed as `sha256(challenge_id)`: an agent that discovers the challenge identifier could compute the flag directly without exploiting the target. That work audits 142 solved transcripts for identifier leakage and hash computation, finding none. This is a shortcut-specific audit rather than a general method-verification framework; OVIS generalizes this single-purpose audit into a reusable, multi-dimension scoring instrument applicable across benchmark designs.

B. Reward hacking and specification gaming

The general phenomenon of an agent satisfying a proxy objective without satisfying the intended objective was named as an open problem in AI safety by Amodei et al. [17] and formalized as “proxies are unhackable only under narrow conditions” by Skalse et al. [18]. Pan et al. [19] showed empirically that more capable reinforcement learning agents exploit reward misspecification *more*, not less, and documented sudden phase transitions from proxy-and-true-reward correlation to outright divergence. DeepMind’s specification-gaming catalog [20] collects dozens of concrete instances of this pattern across RL domains. TrustedSec’s Juice Shop study [5] is, to our knowledge, the first work to document this failure mode with per-run forensic detail (JWT decoding across hundreds of runs) in an agentic cybersecurity benchmark specifically, and is the empirical anchor for this paper. OVIS can be read as an attempt to operationalize the Skalse/Pan/Amodei critique as a checklist applicable to a benchmark’s published methodology, rather than requiring a from-scratch theoretical analysis of every new benchmark’s reward structure.

C. Process-aware grading

A minority of benchmarks in our corpus already grade intermediate process rather than terminal outcome alone. Microsoft’s ExCyTIn-Bench [3] uses graph-grounded, step-level rewards tied to a known SOC investigation graph. ExploitBench [4] grades along a five-tier, sixteen-capability ladder with a deterministic verifier and explicitly no LLM-judge. DARPA’s AI Cyber Challenge [7] requires a patch to functionally close a proven-exploitable vulnerability, not merely to be submitted. None of these works frame themselves as a response to the outcome-validation problem in the general

case; we argue they are best understood as convergent, independently arrived-at instances of the same underlying design principle.

D. The broader CTF and pentesting benchmark landscape

Beyond the sources scored in Section IV, a substantial and fast-growing body of work evaluates LLM agents on offensive tasks using the same outcome-only paradigm audited here. HackSynth [21] introduces a Planner/Summarizer agent evaluated on 200 PicoCTF and OverTheWire challenges with binary flag capture. AIRTbench [23] evaluates frontier models against 70 black-box red-teaming challenges and reports success rates in the 49 to 61% range. Fang et al. [26] show that GPT-4-class agents can autonomously exploit real one-day vulnerabilities given a CVE description, using successful exploitation as the sole outcome signal. Happe and Cito [22] survey nineteen papers in this space and find that only around a quarter evaluate open or locally-hosted models, a coverage gap orthogonal to, but compounding, the grading-design gap this paper documents. Closer to a method-aware design, PentestJudge [24] proposes hierarchical rubrics that grade an agent’s full trajectory against operational requirements rather than a single terminal check, and xOffense [25] fine-tunes a Qwen3-32B backbone specifically for autonomous pentesting and reports 72.72% on AutoPenBench. Deng et al. [12] additionally show that typed tool interfaces alone shift agent performance by 14 percentage points independent of the underlying model, a scaffold-level confound that OVIS treats as orthogonal to, but compounding with, grading-level integrity.

E. Knowledge and threat-intelligence benchmarks

A parallel line of work evaluates LLMs on cybersecurity *knowledge* rather than autonomous exploitation, almost uniformly using multiple-choice question (MCQ) formats structurally identical to the outcome-only designs audited here: CTIBench [27] for threat-intelligence reasoning, SEvenLLM [28] for bilingual incident analysis, CyberMetric [29] for broad security knowledge sourced from NIST and CWE standards, and Meta’s CyberSecEval 3 [30] for dual-use risk and capability assessment. The prevalence of MCQ grading across this adjacent literature suggests the outcome-only pattern we quantify is not specific to CyberSOCEval or to exploitation benchmarks, but is close to the default choice across the field, which strengthens the case for a reusable integrity rubric rather than a one-off critique of any single benchmark.

F. Meta-synthesis and adjacent security evaluation

The International AI Safety Report [31], a government and multi-stakeholder synthesis, itself tracks state-of-the-art trends across four cyber benchmarks and cites the AIXCC 77% discovery figure directly, lending independent weight to the raw capability numbers this paper treats as inputs rather than as its own contribution. NetSPI’s Open LLM Security

Benchmark [32] evaluates a related but distinct property, jail-break resistance traded off against usability, using a dual-axis framework that we did not have sufficient methodological detail to score under OVIS but that shares the same underlying concern about what a single reported number can and cannot support.

G. Scaffold and architecture confounds

A parallel and complementary line of evidence shows that reported capability is highly sensitive to agent scaffold and tool-schema design independent of the underlying model [1, 10, 9]. This paper treats grading-function design as an additional, largely unexamined confound of the same family, orthogonal to scaffold effects.

H. Production deployment reporting

Enterprise and hyperscaler deployments of frontier agentic models against real codebases [6, 14, 15] are, notably, the part of our corpus that most consistently declines to publish a benchmark-style accuracy number at all, instead reporting discrete, independently confirmed findings (CVE assignments, maintainer confirmations) or process metrics such as Visa’s Mean Time to Adapt [6]. We treat this pattern as informative evidence for RQ2 (Section V) rather than a gap in our corpus.

III. CORPUS AND METHODOLOGY

A. Corpus construction

We assembled a corpus of 22 independently published sources spanning five evidentiary tiers: peer-reviewed or preprint academic benchmarks, an industry vendor benchmark blog with full per-run transcript disclosure, a government-run and independently judged competition, enterprise and hyperscaler production deployments, and an industry framework self-evaluation. Sources were included only if they reported at least one quantitative agent performance figure and described, at some level of detail, how that figure was computed. Of the 22 corpus sources, **11** contained sufficient primary-source detail (published methodology sections, worked examples of the grading function, or per-run audit narratives) to score all five OVIS dimensions defensibly; the remaining 11 are retained in the broader corpus for other analyses in this research program but are excluded from the OVIS scoring reported here and explicitly flagged as INSUFFICIENT_EVIDENCE pending deeper review.

B. The OVIS rubric

Each source s is scored on five dimensions $d \in \{MV, SA, HG, IG, RT\}$, each on an ordinal scale $\{0, 1, 2\}$ (absent, partial, explicit and documented):

MV — Method Verification

Does the grading function (or a documented post-hoc audit of it) check *how* the outcome was reached, rather than only *that* a terminal state was reached?

SA — Shortcut/Contamination Audit

Is there an explicit, documented audit for shortcut-solving, answer-leakage, or reward hacking, with results reported rather than merely asserted?

HG — Human Ground-Truth Anchor

Is agent performance anchored to an independent human baseline, such as solve time, maintainer confirmation, or expert review of the evaluation instrument itself?

IG — Grader Independence

Is the grading function deterministic or otherwise independent of the system under test, i.e., not a same-family LLM-judge or self-graded output?

RT — Reproducibility/Transparency

Are the harness, grading logic, or raw per-run transcripts made available for independent re-audit?

The Outcome-Validation Integrity Score is

$$\text{OVIS}(s) = \frac{\sum_{d \in \{MV, SA, HG, IG, RT\}} \text{score}_d(s)}{10} \times 100\%. \quad (1)$$

We additionally classify each scored source’s grading-function design into one of three categories, independent of its OVIS score: OUTCOME-ONLY (binary flag capture, multiple-choice accuracy, or pass@ k on a terminal state), PROCESS-AWARE (tiered capability ladders, graph-grounded step rewards, or functional/adversarial validation of an end effect), and OUTCOME-ONLY-BUT-AUDITED (an outcome-only grading function whose integrity was subsequently established or refuted by an independent manual audit, as in the TrustedSec case). This classification lets us test whether OVIS varies systematically with *how* a benchmark was designed to measure success, independent of the raw score any individual benchmark receives.

C. Scoring procedure

The author read each source’s methodology section, worked examples, and (where available) released harness code, and assigned scores per dimension with a written justification quoting the specific methodological evidence relied upon (single-rater scoring in this preprint; see Section VI). Algorithm 1 summarizes the scoring and aggregation procedure as implemented.

IV. RESULTS

A. Ranked OVIS scores

Table 1 reports OVIS scores for all 11 scored sources, ranked descending. Scores range from 30.0% (CAIBench’s Cybench-subset evaluation, pure pass@1 with deterministic but outcome-only grading) to 90.0% (tied between TrustedSec’s audited local-model benchmark and DARPA’s AIxCC). The corpus mean is 60.0% ($\sigma = 20.0$).

Table 1: OVIS scores by source, ranked descending. MV/SA/HG/IG/RT are 0–2 dimension scores; OVIS is the percentage of Eq. 1.

Rank	Source	MV	SA	HG	IG	RT	Raw/10	OVIS (%)	Design category
1	TrustedSec (2026), Juice Shop local-model eval [5]	2	2	1	2	2	9	90.0	outcome-only-but-audited
2	DARPA AIXCC 2025 Finals [7]	2	2	1	2	2	9	90.0	process-aware
3	Sultan (2026), XBOW-104 scaffold study [1]	1	2	0	2	2	7	70.0	outcome-only
4	Visa VVAH / Project Glasswing [6]	2	1	2	2	0	7	70.0	process-aware-unpublished
5	Cybench 2024 [8]	1	0	2	2	2	7	70.0	outcome-only
6	ExploitBench 2026 (v8-bench) [4]	2	1	0	2	1	6	60.0	process-aware
7	CyberSOCEval 2025 [2]	0	1	0	2	2	5	50.0	outcome-only
8	Microsoft ExCyTIn-Bench 2025 [3]	2	0	0	2	1	5	50.0	process-aware
9	EnIGMA 2024 [9]	0	0	0	2	2	4	40.0	outcome-only
10	D-CIPHER 2025 [10]	0	0	0	2	2	4	40.0	outcome-only
11	CAIBench 2025 (Cybench subset) [11]	0	0	0	2	1	3	30.0	outcome-only

Algorithm 1: OVIS corpus scoring**Input:** corpus C of candidate sources**Output:** ranked table T , group statistics G

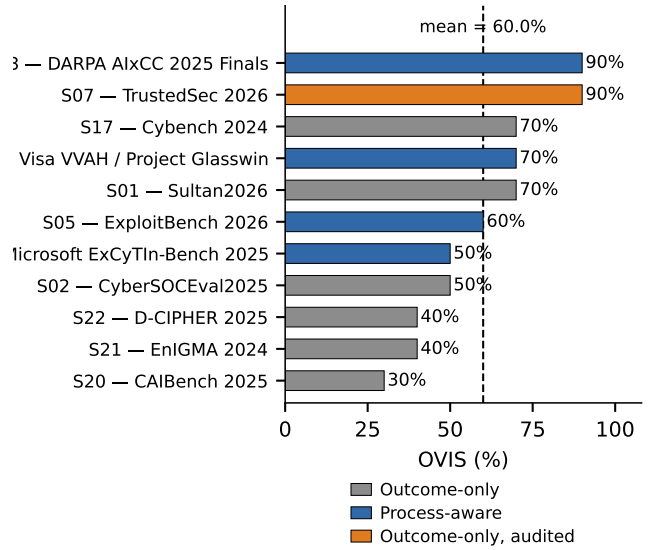
1. $S \leftarrow \{s \in C : \text{depth}(s) \geq \tau_{\text{evidence}}\}$
2. **for** each $s \in S$: score $(MV, SA, HG, IG, RT) \in \{0, 1, 2\}^5$ with justification; assign $\text{design}(s)$
3. **for** each $s \in S$: compute $\text{OVIS}(s)$ per Eq. 1
4. $T \leftarrow \text{sort } S \text{ by } \text{OVIS}(s) \text{ descending}$
5. **for** each design category k : $G_k \leftarrow \text{mean}(MV), \text{mean}(\text{OVIS}) \text{ over } \{s : \text{design}(s) = k\}$
6. **return** T, G

Figure 1: OVIS scoring and aggregation procedure.**Table 2:** Mean MV sub-score and mean OVIS by grading-design category.

Design category	n	Mean MV (%)	Mean OVIS (%)
Outcome-only	6	16.7	50.0
Process-aware	4	100.0	67.5
Outcome-only, audited	1	100.0	90.0

B. Metric design predicts method-verification integrity

Grouping sources by grading-design category (Table 2) shows a large gap in the method-verification (MV) sub-score between OUTCOME-ONLY designs ($n=6$: CyberSOCEval, Cybench, EnIGMA, D-CIPHER, CAIBench, and Sultan’s XBOW study) and PROCESS-AWARE designs ($n=4$: ExCyTIn-Bench, ExploitBench, AIXCC, Visa VVAH). Mean MV as a percentage of its 2-point maximum is 16.7% for outcome-only designs versus 100.0% for process-aware designs; every process-aware source in our corpus scored the maximum on method verification, while five of six outcome-only sources scored zero. Mean overall OVIS is correspondingly higher for process-aware designs (67.5%) than outcome-only designs (50.0%), though the gap narrows at the OVIS level because outcome-only designs in this corpus tend to compensate with strong human ground-truth anchoring (Cybench) or reproducibility (EnIGMA, D-CIPHER).

**Figure 2:** Ranked OVIS scores by source and grading-design category. Dashed line marks the corpus mean (60.0%).**C. Auditing rescues, but is rare**

The single OUTCOME-ONLY-BUT-AUDITED source in our corpus (TrustedSec) achieves the joint-highest OVIS score in the entire corpus (90.0%) despite using the same grading paradigm (string-match on an HTTP response body) as five of the six lowest-scoring sources. The difference is entirely attributable to SA and MV: TrustedSec’s authors decoded every passing JWT and traced every SQLi login across 4,800 runs, discovering that a challenge with a nominal 98.5% pass rate had an intended-method rate of 0%: across 681 total runs on this challenge, all six benchmarked models combined, the RS256-to-HS256 algorithm-confusion attack the challenge was designed to test was never performed. Within the one model whose passing runs were fully decoded and published (nemotron-3-super, $n=69$ passes), every pass was attributable instead to token replay via an unrelated SQL-injection exploit (28 of 69) or to the structurally simpler `alg:none` forgery

attack (41 of 69). No other source in our corpus reports an equivalently granular per-run forensic audit of its own passing results.

V. DISCUSSION

A. RQ1: Does grading design predict gameability?

Our results support a qualified yes. Every process-aware source in this corpus scored the maximum method-verification sub-score; every outcome-only source scored at or near zero on the same dimension unless independently audited. This is consistent with, and quantifies, the mechanism predicted by the reward-hacking literature reviewed in Section III: a grading function that checks a terminal string or state cannot, by construction, distinguish an intended exploitation path from an unintended one that happens to produce the same terminal artifact, which is precisely the “proxy versus true objective” gap Skalse et al. [18] formalize and Pan et al. [19] show gets *worse*, not better, as agents become more capable. XBOW’s flag-shortcut audit and TrustedSec’s JWT-decoding audit are two independent instances of researchers recognizing this limitation and adding a compensating control outside the automated grading loop, rather than redesigning the grading function itself.

B. RQ2: Why do production deployments not report benchmark-style numbers?

The corpus’s two production-deployment sources, Visa VVAH and, by report, Google’s Big Sleep and CodeMender programs [14], are the only entries that explicitly and voluntarily decline to publish an accuracy percentage of any kind, instead reporting either discrete, externally confirmed findings (CVE assignments, maintainer acknowledgment) or a purpose-built process metric. Visa’s Mean Time to Adapt explicitly measures inventory freshness, exploitable paths per release, and validation-cycle time rather than a closure-count or detection-rate. We interpret this as indirect but convergent evidence for our central claim: organizations whose findings face real adversarial and regulatory scrutiny appear to have independently concluded that outcome-rate metrics are not defensible enough to publish, and have engineered around the same failure mode this paper formalizes, via adversarial validation panels (Visa’s S6/S11 stages) rather than via a rubric. Visa’s architecture is, in OVIS terms, strong on MV, HG, and IG (2, 2, 2) but scores zero on RT, since none of its findings, transcripts, or grading logic are released for independent re-audit. This illustrates that process rigor and public auditability are orthogonal properties: a deployment can be simultaneously highly rigorous and entirely unverifiable by outside parties.

C. Practical recommendation

We recommend that any reported agentic cybersecurity benchmark number be accompanied by, at minimum, an explicit statement of which OVIS dimensions were satisfied,

particularly MV and SA. Where a grading function is unavoidably outcome-only, for example because ground-truth mechanism labeling is expensive to construct at scale, we recommend a TrustedSec-style sampled forensic audit of a subset of passing runs as a low-cost, high-value compensating control, and that the audited subset and its findings be published alongside the headline number.

VI. THREATS TO VALIDITY

Corpus coverage and scoring subjectivity. Eleven of 22 candidate sources were excluded from scoring for insufficient documented methodological detail. This is a deliberate precision-over-recall choice but means the scored corpus is not a random or complete sample of the field. Scoring in this preprint was performed by a single author; inter-rater reliability across independent scorers has not yet been established and is planned future work (Section VII).

Ordinal, not interval, dimensions. The 0/1/2 scale per dimension is ordinal; treating OVIS as a linear percentage assumes equal spacing between “absent,” “partial,” and “explicit,” which may not hold uniformly across dimensions.

Small n per design category. With $n=6$ outcome-only and $n=4$ process-aware sources, the group means in Table 2 are directionally suggestive rather than statistically confirmatory. No significance test is reported given the sample size, and we explicitly avoid overclaiming statistical significance here.

Self-selection in what gets published in this level of detail. Sources with the methodological detail needed to score OVIS at all may be systematically more rigorous authors to begin with, which could inflate the corpus’s overall integrity relative to the true population of agentic cybersecurity benchmarks in circulation, including many vendor leaderboards with no published methodology at all.

VII. FUTURE WORK

Immediate extensions include expanding the scored corpus toward the full 22-source pool and beyond as methodological detail is obtained for the currently-excluded sources, multi-rater scoring with reported inter-rater agreement such as Cohen’s κ , and applying the OVIS rubric outside cybersecurity to agentic coding and computer-use benchmarks that share the same terminal-state grading pattern. A further direction, informed by the psychometrics literature on item response theory (IRT) for NLP evaluation [33], is to fit a joint model of benchmark item difficulty and model ability across sources, conditioned on OVIS as a covariate, to test whether low-OVIS benchmarks systematically overstate capability relative to high-OVIS benchmarks measuring comparable tasks.

VIII. CONCLUSION

We introduced the Outcome-Validation Integrity Score, a five-dimension rubric for auditing whether an agentic cybersecurity benchmark’s grading function can be satisfied with-

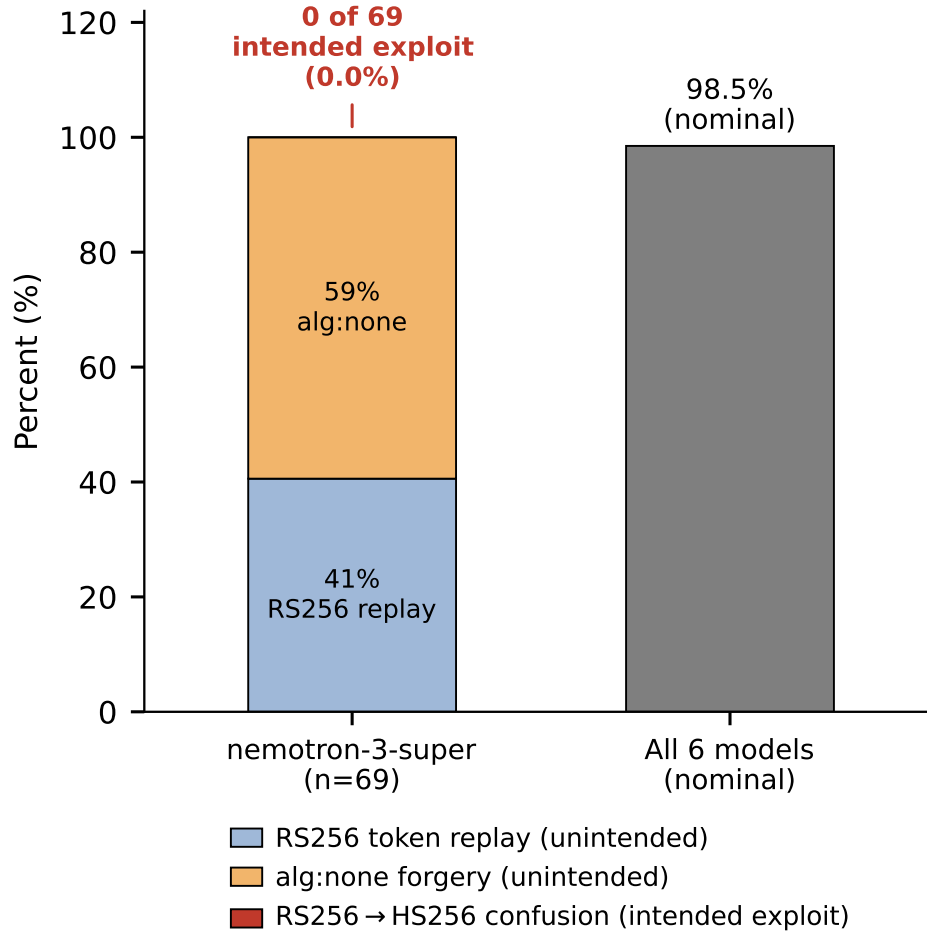


Figure 3: Nominal pass rate versus intended-method rate, TrustedSec `jwt-weak-medium` case study [5]. Left bar: full mechanism breakdown for the one model with a fully audited, published per-run decode (nemotron-3-super, $n=69$ passing runs); the intended RS256→HS256 exploit was used in 0 of 69. Right bar: the challenge’s nominal pass rate as reported across all six benchmarked models.

out the intended capability being exercised. Applied to eleven independently documented sources, OVIS shows a substantial gap in method-verification integrity between outcome-only grading designs (16.7%) and process-aware designs (100.0%), and identifies post-hoc manual auditing as a rare but effective compensating control, illustrated by a documented case in which a nominally 98.5%-passing benchmark challenge had a true intended-method success rate of zero across 681 runs. We release our rubric and corpus to support future, larger-scale, multi-rater audits of the rapidly growing body of agentic cybersecurity evaluation claims.

REFERENCES

- [1] Z. Sultan, “Backbone or Backbone-Architecture? A Controlled Study of LLM Agents on Web Penetration-Testing CTFs,” working draft, Jun. 2026.
- [2] L. Deason *et al.*, “CyberSOCEval: Benchmarking LLMs Capabilities for Malware Analysis and Threat Intelligence Reasoning,” Meta / CrowdStrike, Sep. 2025, rev. Nov. 2025.
- [3] Microsoft Security, “ExCyTIn-Bench: Evaluating LLM Agents on Autonomous Threat Investigation,” Microsoft Security Blog, 2025.
- [4] ExploitBench Contributors, “ExploitBench: Tiered Capability Evaluation for LLM Exploit Synthesis (v8-bench),” 2026.
- [5] B. McGrath, “Benchmarking Self-Hosted LLMs for Offensive Security,” *TrustedSec Blog*, Apr. 2026.
- [6] R. Taneja and S. Kumaraswamy, “Visa Releases Its AI-Powered Cyber Defense System to Open Source,” Visa Corporate Perspectives, Jun. 2026; Visa, “Visa Vulnerability Agentic Harness,” GitHub, 2026.

- [7] DARPA / ARPA-H, “AI Cyber Challenge (AIXCC) Final Competition Results,” Aug. 2025.
- [8] A. K. Zhang *et al.*, “Cybench: A Framework for Evaluating Cybersecurity Capabilities and Risks of Language Models,” *arXiv:2408.08926*, 2024.
- [9] T. Abramovich *et al.*, “EnIGMA: Interactive Tools Substantially Assist LM Agents in Finding Security Vulnerabilities,” *arXiv:2409.16165*, 2024.
- [10] “D-CIPHER: Dynamic Collaborative Intelligent Multi-Agent System with Planner and Heterogeneous Executors for Offensive Security,” *arXiv:2502.10931*, 2025.
- [11] Alias Robotics, “Cybersecurity AI Benchmark (CAIBench): A Meta-Benchmark for Evaluating Cybersecurity AI Agents,” *arXiv:2510.24317*, 2025.
- [12] G. Deng *et al.*, “What Makes a Good LLM Agent for Real-world Penetration Testing?,” *arXiv:2602.17622*, 2026.
- [13] Alias Robotics, “CAI: Cybersecurity AI, an Open Framework for Autonomous Offensive and Defensive Security,” GitHub, 2025.
- [14] Google DeepMind and Google Project Zero, “Big Sleep: Real-World Vulnerability Discovery with Large Language Models,” Google Security Blog, Nov. 2024; “Google AI ‘Big Sleep’ Stops Exploitation of Critical SQLite Vulnerability Before Hackers Act,” *The Hacker News*, Jul. 2025.
- [15] AISLE, “AISLE Discovered New OpenSSL Vulnerabilities,” AISLE Research Blog, Oct. 2025.
- [16] Z. Sheng, Z. Chen, Q. Xu, K. Zhu, and J. Huang, “FuzzingBrain V2: A Multi-Agent LLM System for Automated Vulnerability Discovery and Reproduction,” *arXiv:2605.21779*, 2026.
- [17] D. Amodei, C. Olah, J. Steinhardt, P. Christiano, J. Schulman, and D. Mané, “Concrete Problems in AI Safety,” *arXiv:1606.06565*, 2016.
- [18] J. Skalse, N. H. R. Howe, D. Krasheninnikov, and D. Krueger, “Defining and Characterizing Reward Hacking,” *arXiv:2209.13085*, 2022.
- [19] A. Pan, K. Bhatia, and J. Steinhardt, “The Effects of Reward Misspecification: Mapping and Mitigating Misaligned Models,” *arXiv:2201.03544*, 2022.
- [20] V. Krakovna *et al.*, “Specification Gaming: The Flip Side of AI Ingenuity,” DeepMind Research Blog, Apr. 2020.
- [21] L. Muzsai, D. Imolai, and A. Lukács, “HackSynth: LLM Agent and Evaluation Framework for Autonomous Penetration Testing,” *arXiv:2412.01778*, 2024.
- [22] A. Happe and J. Cito, “Benchmarking Practices in LLM-Driven Offensive Security: Testbeds, Metrics, and Experiment Design,” *arXiv:2504.10112*, 2025.
- [23] “AIRTbench: Measuring Autonomous AI Red Teaming Capabilities in Language Models,” *arXiv:2506.14682*, 2025.
- [24] “PentestJudge: Judging Agent Behavior Against Operational Requirements,” *arXiv:2508.02921*, 2025.
- [25] “xOffense: AI-driven Autonomous Pentesting with Offensive Knowledge-Enhanced LLMs,” *arXiv:2509.13021*, 2025.
- [26] R. Fang, R. Bindu, A. Gupta, and D. Kang, “LLM Agents can Autonomously Exploit One-day Vulnerabilities,” *arXiv:2404.11625*, 2024.
- [27] M. T. Alam, D. Bhusal, L. Nguyen, and N. Rastogi, “CTIBench: A Benchmark for Evaluating LLMs in Cyber Threat Intelligence,” *arXiv:2406.07599*, 2024.
- [28] H. Ji *et al.*, “SEvenLLM: Benchmarking, Eliciting, and Enhancing Abilities of Large Language Models in Cyber Threat Intelligence,” *arXiv:2405.03446*, 2024.
- [29] N. Tihanyi, M. A. Ferrag, R. Jain, T. Bisztray, and M. Debbah, “CyberMetric: A Benchmark Dataset Based on Retrieval-Augmented Generation for Evaluating LLMs in Cybersecurity Knowledge,” *arXiv:2402.07688*, 2024.
- [30] S. Wan *et al.*, “CyberSecEval 3: Advancing the Evaluation of Cybersecurity Risks and Capabilities in Large Language Models,” *arXiv:2408.01605*, 2024.
- [31] “International AI Safety Report 2026,” *arXiv:2602.21012*, 2026.
- [32] NetSPI, “Open LLM Security Benchmark: Balancing Security and Usability of Large Language Models,” NetSPI, 2025.
- [33] J. P. Lalor, H. Wu, and H. Yu, “Building an Evaluation Scale using Item Response Theory,” in *Proc. EMNLP*, 2016, *arXiv:1605.08889*.